

WorkFlow Global HRMS - Part 3 Report

Authentication & Role-Based Access Control (RBAC)

1. Executive Summary

This report documents the implementation of Part 3 of the WorkFlow Global HRMS project, focusing on authentication mechanisms, demo login functionality, and comprehensive Role-Based Access Control (RBAC) system. The implementation provides secure access control while enabling easy role switching for demonstration purposes.

2. Authentication Architecture

The authentication system implements a simplified demo-ready approach:

Components:

- AuthService: Core authentication logic
- LoginRequest/LoginResponse DTOs
- UserProfile model
- GraphQL mutations and queries

Features:

- Email/password authentication
- Token-based session management
- User profile retrieval
- Demo role switching capability

Security Note:

The current implementation uses simplified password validation for demo purposes. Production deployment should implement:

- BCrypt or Argon2 password hashing
- JWT token generation and validation
- Refresh token mechanism
- Rate limiting and brute force protection

WorkFlow Global HRMS - Part 3 Report

Authentication & Role-Based Access Control (RBAC)

3. Demo Login Credentials

Email	Password
admin@workflowglobal.com	admin123
hr@workflowglobal.com	hr123
manager@workflowglobal.com	manager123
john.doe@workflowglobal.com	employee123

GraphQL Mutations:

1. Login:

```
mutation {  
  login(request: {  
    email: "admin@workflowglobal.com"  
    password: "admin123"  
  }) {  
    success  
    message  
    token  
    user { id name email role }  
  }  
}
```

2. Switch Demo Role:

```
mutation {  
  switchDemoRole(  
    userId: "emp-001"  
    newRole: MANAGER  
  ) {  
    success  
    user { role }  
  }  
}
```

3. Get Current User:

```
query {  
  getCurrentUser(userId: "emp-001") {  
    id name email role department  
  }  
}
```

WorkFlow Global HRMS - Part 3 Report

Authentication & Role-Based Access Control (RBAC)

}

WorkFlow Global HRMS - Part 3 Report

Authentication & Role-Based Access Control (RBAC)

4. Role-Based Access Control (RBAC)

The RBAC system implements a comprehensive permission matrix:

Roles:

1. Admin - Full system access
2. HR - Human resources functions
3. Manager - Team management
4. Employee - Self-service access

Permission Format:

resource:action or resource:action:scope

Examples:

- employee:read (Read all employees)
- leave:approve (Approve leave requests)
- attendance:read:own (Read own attendance)
- document:verify (Verify documents)

WorkFlow Global HRMS - Part 3 Report

Authentication & Role-Based Access Control (RBAC)

5. RBAC Capability Matrix

Admin Permissions:

- Full access to all modules
- Employee management (CRUD)
- Attendance tracking
- Leave approval
- Payroll management
- Document verification
- Expense approval
- Performance management
- Training administration
- Recruitment management
- Announcement posting
- Analytics access
- Copilot usage

HR Permissions:

- Employee data (read/write)
- Attendance viewing
- Leave approval
- Payroll viewing
- Document verification
- Expense viewing
- Performance viewing
- Training management
- Recruitment management
- Announcement posting
- Analytics access
- Copilot usage

Manager Permissions:

- Team employee viewing
- Team attendance viewing
- Leave approval (team)
- Expense approval (team)
- Performance management (team)
- Training viewing
- Announcement viewing
- Analytics access
- Copilot usage

Employee Permissions:

- Own attendance (read)
- Own leave (read/write)
- Own documents (read/write)

WorkFlow Global HRMS - Part 3 Report

Authentication & Role-Based Access Control (RBAC)

- Own expenses (read/write)
- Own performance (read)
- Training viewing
- Announcement viewing
- Copilot usage

WorkFlow Global HRMS - Part 3 Report

Authentication & Role-Based Access Control (RBAC)

6. Authorization Methods

The RBACService provides specialized authorization methods:

1. CanAccessResource(role, resource, action)
 - Generic permission check
 - Returns true if role has permission
2. CanAccessEmployeeData(role, requestingUserId, targetUserId)
 - Validates employee data access
 - Admin/HR: All employees
 - Manager: Team members
 - Employee: Self only
3. CanApproveLeave(role)
 - Admin, HR, Manager can approve
4. CanApproveExpense(role)
 - Admin, Manager can approve
5. CanManageRecruitment(role)
 - Admin, HR only
6. CanVerifyDocuments(role)
 - Admin, HR only
7. CanPostAnnouncements(role)
 - Admin, HR only
8. CanViewAnalytics(role)
 - Admin, HR, Manager

WorkFlow Global HRMS - Part 3 Report

Authentication & Role-Based Access Control (RBAC)

7. Implementation Details

File Structure:

Authentication:

- EmployeeFeature.Application/Services/AuthService.cs
- EmployeeFeature.Application/DTOs/LoginRequest.cs
- EmployeeFeature.Application/DTOs/LoginResponse.cs
- EmployeeFeature.GraphQL/AuthMutation.cs
- EmployeeFeature.GraphQL/AuthQuery.cs

Authorization:

- HRMS.Shared.Application/Authorization/RBACService.cs

Usage in GraphQL Resolvers:

```
public async Task<LeaveRequest> ApproveLeave(
    string leaveId,
    [Service] IRBACService rbac,
    [Service] IHttpContextAccessor context)
{
    var userRole = GetUserRole(context);
    if (!rbac.CanApproveLeave(userRole))
        throw new UnauthorizedAccessException();
    // Proceed with approval
}
```


WorkFlow Global HRMS - Part 3 Report

Authentication & Role-Based Access Control (RBAC)

8. Security Best Practices

Current Implementation:

- Role-based permission checks
- Resource-level authorization
- User context validation
- Demo-friendly role switching

Production Recommendations:

1. Password Security:

- Implement BCrypt/Argon2 hashing
- Enforce strong password policies
- Add password reset functionality

2. Token Management:

- Use JWT with proper expiration
- Implement refresh tokens
- Store tokens securely (HttpOnly cookies)

3. Session Management:

- Track active sessions
- Implement logout functionality
- Add session timeout

4. API Security:

- Rate limiting
- CORS configuration
- Input validation
- SQL injection prevention (EF Core handles this)

5. Audit Logging:

- Log authentication attempts
- Track authorization failures
- Monitor suspicious activities

6. Multi-Factor Authentication:

- Add 2FA for sensitive roles
- SMS or authenticator app support

WorkFlow Global HRMS - Part 3 Report

Authentication & Role-Based Access Control (RBAC)

9. Testing Scenarios

Authentication Tests:

1. Valid login with correct credentials
2. Invalid login with wrong password
3. Login with non-existent email
4. Get current user profile
5. Switch demo role successfully

Authorization Tests:

1. Admin accessing all resources
2. HR approving leave requests
3. Manager approving team expenses
4. Employee accessing own data only
5. Employee denied access to others data
6. Manager denied document verification
7. Employee denied recruitment access

Edge Cases:

1. Concurrent role switches
2. Token expiration handling
3. Invalid user ID in requests
4. Missing authorization headers
5. Malformed permission strings

WorkFlow Global HRMS - Part 3 Report

Authentication & Role-Based Access Control (RBAC)

10. Integration Guide

Frontend Integration:

1. Login Flow:

- Call login mutation with credentials
- Store token in localStorage/sessionStorage
- Store user profile in state management
- Redirect to dashboard

2. Authorization Checks:

- Check user role before rendering UI
- Hide/disable unauthorized actions
- Handle 401/403 responses gracefully

3. Role Switching (Demo):

- Add role switcher in dev mode
- Call switchDemoRole mutation
- Update local user state
- Refresh UI based on new permissions

4. Session Management:

- Check token validity on app load
- Implement auto-logout on expiration
- Add logout functionality

Backend Integration:

1. Register Services:

```
services.AddScoped<IAuthService, AuthService>();  
services.AddScoped<IRBACService, RBACService>();
```

2. Add to GraphQL:

```
.AddMutationType<AuthMutation>()  
.AddQueryType<AuthQuery>()
```

3. Use in Resolvers:

Inject IRBACService and check permissions

WorkFlow Global HRMS - Part 3 Report

Authentication & Role-Based Access Control (RBAC)

11. Conclusion

Part 3 implementation successfully delivers:

Authentication:

- Demo-ready login system
- 4 pre-configured user accounts
- Role switching for demonstrations
- GraphQL mutations and queries
- User profile management

Authorization (RBAC):

- Comprehensive permission matrix
- 4 distinct roles with clear capabilities
- Resource-level access control
- Specialized authorization methods
- Easy integration with GraphQL resolvers

The system is now ready for:

- Frontend integration
- Business logic implementation
- Production security hardening
- User acceptance testing

Next Steps:

- Implement JWT token generation
- Add password hashing
- Create authorization middleware
- Add audit logging
- Implement session management

Report Generated: 2026-06-23 13:09:39